

Một nửa thế giới đang bị hack, bị mã hóa tổng tiền đúng kỳ nghỉ lễ năm nay. CVE-2026-31431, CVE-2026-41940, và mới nhất là một lỗ hổng CloudLinux nữa vừa xuất hiện sáng sớm 1/5.

Mình vận hành hosting nhiều năm, chưa bao giờ thấy tốc độ phát hiện CVE mới dày đặc và hàng loạt như hiện nay.

Ngày trước hacker phải chuẩn bị rất kỹ. Lên kịch bản, recon target, build exploit, đánh nhanh rút gọn. Quy mô ảnh hưởng rất nhỏ do sức người có hạn. Một nhóm 5-10 người giỏi cũng chỉ tấn công được vài chục đến vài trăm hệ thống là cùng.

Còn bây giờ thì khác hẳn. Một CVE mới được công bố là gần như ngay trong đêm hacker đã càn quét cả thế giới. Quy trình đóng gói chuyên nghiệp đến đáng sợ, script khai thác tự động, exfil dữ liệu, mã hóa tổng tiền, xóa dấu vết. Tất cả trong một payload chạy không cần con người can thiệp.

Mình nghĩ chuyện này chắc chắn có sự hỗ trợ rất sâu của AI. Một nhóm cá nhân hay một tổ chức truyền thống không thể có năng lực phản ứng nhanh đến vậy. Phải có hệ thống AI agent đọc CVE feed, tự sinh exploit từ description, tự scan IP toàn cầu, tự chain với các tool có sẵn. Mình không thấy cách giải thích nào khác hợp lý hơn.

Đêm 30/4 náo loạn kéo dài đến sáng 1/5. Vừa thử phào với CVE cPanel auth bypass, vừa đi vá Copy Fail kernel Linux thì thêm lỗi CloudLinux mới. Lỗi mới này 90% thế giới đều bị. Phát hiện cách đây gần nửa ngày rồi, CloudLinux mới chỉ ghi nhận và đang chuẩn bị patch, chưa có bản fix chính thức. Trong khi đó hacker đã chạy script khai thác từ đêm.

Cộng thêm việc training model AI riêng để phục vụ mục đích tấn công hay phòng thủ đang thành cơn sốt chưa từng có. Cả cá nhân lẫn tổ chức đều đầu tư.

Lưu ý là các model AI public như OpenAI, Claude đều chặn việc lạm dụng AI để tấn công hàng loạt hệ thống người khác. Trước đây cũng có người tìm cách lách prompt để lạm dụng được, nhưng giờ AI phát triển nhiều rồi, các kỹ thuật lách luật đang bị giới hạn triệt để. Hậu quả là nhà nhà đầu tư phần cứng để tự training model AI riêng. Giá GPU, RAM, máy Mac tăng đột biến không phải do nhu cầu dev hay gaming, mà do làn sóng tự host AI cho các mục đích không kiểm duyệt được.

Người người mua phần cứng training AI về phòng thủ. Người người mua training AI phục vụ mục đích riêng, whitehat, greyhat, blackhat đều có.

Chính phủ thì đầu tư AI cho bảo mật quốc phòng và công nghệ quân sự. Một cuộc chạy đua vũ trang AI thầm lặng đang diễn ra ở mọi tầng.

Quan điểm của mình sau đêm trắng vừa rồi.

Thứ nhất, kỷ nguyên patch khi rảnh đã chấm dứt. Trước đây từ lúc CVE công bố đến lúc bị scan có thể vài tuần. Giờ là vài giờ. Đội ngũ ops không thể vận hành theo lịch giờ hành chính nữa. Hoặc có quy trình patch tự động trong 4-6 giờ kể từ disclosure, hoặc chấp nhận rủi ro mất hệ thống.

Thứ hai, defense in depth không còn là lựa chọn mà là yêu cầu sống còn. Một lớp bảo vệ duy nhất chắc chắn sẽ thủng. Hosting phải có WAF, IDS, kernel hardening, file integrity monitoring, behavior anomaly

detection, backup offsite có versioning. Mỗi lớp giảm 50-70% rủi ro, chồng nhiều lớp mới ra được con số an toàn chấp nhận được.

Thứ ba, AI defense bắt buộc phải có. Khi attacker dùng AI thì defender không dùng AI là cầm chắc thua. Imunify360 đang đi đúng hướng khi tích hợp AI detect IOC tự động. Cloudflare cũng vậy. Các tool truyền thống dựa vào signature đã hết thời.

Thứ tư, chi phí bảo mật sẽ tăng mạnh trong 12 tháng tới. Subscription cho KernelCare, Imunify360, premium WAF, AI threat detection, backup có versioning, compliance audit. Cộng dồn không hề rẻ. Nhưng chi phí một lần bị ransomware còn đắt gấp 100 lần. Đây là lúc các business operator phải cân lại budget IT, không phải cắt mà là tăng đáng kể.

Thứ năm, và đây là điều khiến mình suy nghĩ nhiều nhất. Chúng ta đang chứng kiến giai đoạn đầu của một thế giới mà tấn công và phòng thủ đều được automate hoàn toàn. Con người chỉ còn vai trò ra quyết định chiến lược. Cuộc chiến diễn ra ở tốc độ machine, không phải tốc độ con người. Ai chậm hơn AI vài giờ là thua.

Anh em làm IT, dev, ops, sysadmin, đặc biệt ai đang vận hành hệ thống cho người khác.

Đêm nay, ngày mai và những ngày tiếp theo, hãy theo dõi sát các CVE feed. Đừng đi nghỉ lễ mà không có ai monitor server. Nếu phải đi, set up tự động hóa và alert tối thiểu trước khi đi.

-Thanh Nguyen-